

Huntsman Challenge 4: Sicherheit und Compliance Management

Autor: Maximilian Jakob Maag B.Sc.

Version: 1.0

1 Intro

Diese Challenge befasst sich mit der Sicherung und Compliance der verwalteten Infrastruktur. Sie werden Sicherheitsrichtlinien durchsetzen, die Infrastruktur überwachen und sicherstellen, dass alle Systeme den Compliance-Anforderungen entsprechen.

2 Aufgaben

2.1 Aufgabe 1

Erstellen Sie ein Sicherheits-Hardening Playbook, das auf alle verwalteten Server angewandt wird.

Das Playbook sollte:

- SSH Key Based Authentication erzwingen (Passwort Authentifizierung deaktivieren)
- Firewall Regeln konfigurieren (nur notwendige Ports öffnen)
- fail2ban installieren und konfigurieren
- sudo Zugriff auf Basis von Gruppen regeln
- Unwichtige Services deaktivieren
- SELinux oder AppArmor aktivieren

2.2 Aufgabe 2

Implementieren Sie ein User Access Management Playbook.

Das Playbook sollte:

- Autorisierte Benutzer auf den Systemen verwalten
- SSH Public Keys zentral verwalten
- sudo Konfigurationen durchsetzen
- Inaktive Accounts deaktivieren
- Audit Logs für alle Zugriffe generieren

2.3 Aufgabe 3

Erstellen Sie ein Security Scanning und Vulnerability Assessment Playbook.

Das Playbook sollte:

- Regelmäßig Sicherheits-Scans durchführen (z.B. mit Nessus, OpenVAS)
- Package Vulnerabilities überprüfen
- Firewall Regeln auf Offenheiten prüfen
- SSL/TLS Konfigurationen validieren
- Befunde in einem zentralen System sammeln und melden

2.4 Aufgabe 4

Implementieren Sie Compliance Checking Playbooks für verschiedene Standards:

- CIS Benchmarks
- GDPR Anforderungen (Datenschutz)
- PCI DSS (für Payment Systems)
- Custom Company Policies

2.5 Aufgabe 5

Erstellen Sie ein Playbook zur Patch Management und Updates.

Das Playbook sollte:

- Sicherheits-Updates automatisch installieren
- Critical Patches sofort einspielen
- Regelmäßige OS Updates nach Testlauf durchführen
- System nach Updates neu starten (mit Wartungsfenster)
- Compatibility mit laufenden Services prüfen

2.6 Aufgabe 6

Implementieren Sie ein Logging und Monitoring Playbook für Security Events.

Das Playbook sollte:

- Centralized Log Collection einrichten (z.B. ELK Stack, Splunk)

- Failed Login Attempts loggen und monitoren
- Privilege Escalation Events tracken
- Datei-Änderungen auf kritischen Systemen monitoren
- Real-time Alerts für verdächtige Aktivitäten generieren

2.7 Aufgabe 7

Erstellen Sie ein Incident Response Playbook.

Das Playbook sollte:

- Verdächtige Server isolieren können
- Forensische Daten sammeln
- Logs für Incident Investigation aufbewahren
- Automatische Notification an Security Team
- Rollback Prozeduren für kompromittierte Systeme

2.8 Aufgabe 8

Dokumentieren Sie Ihre Sicherheitspolicies und Compliance Anforderungen.

Die Dokumentation sollte enthalten:

- Sicherheitsrichtlinien für alle Server
- Compliance Anforderungen und deren Umsetzung
- Security Incident Response Prozess
- Regelmäßige Security Audit Schedule